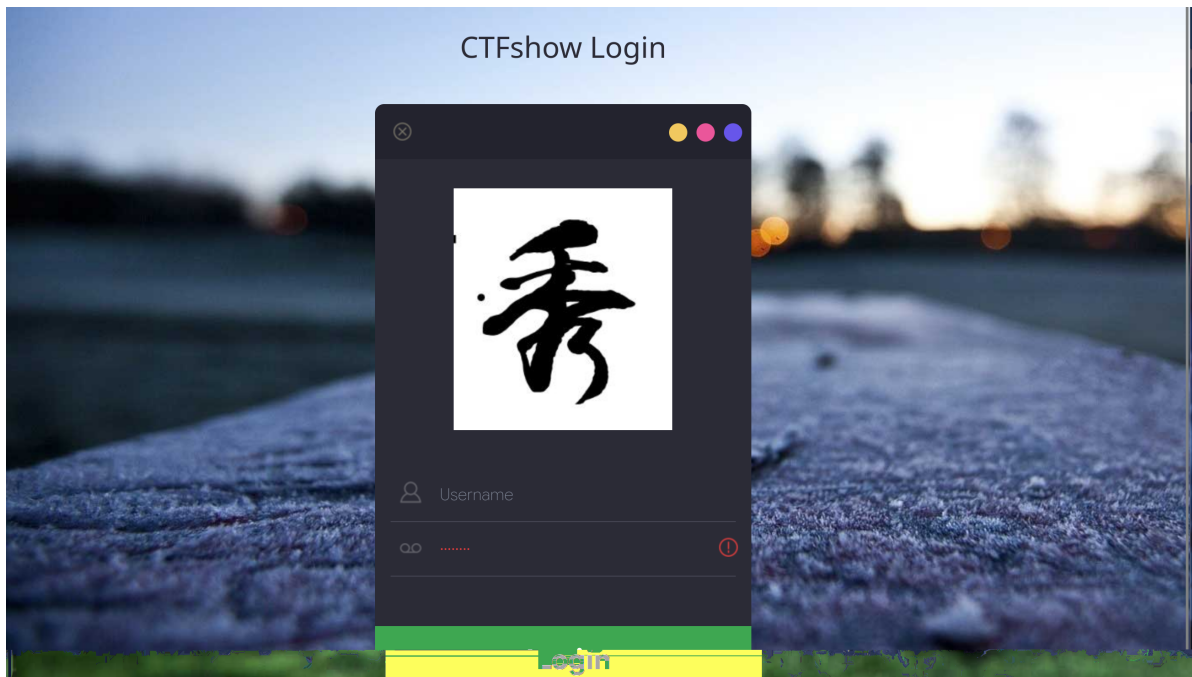




提示：打无密码的mysql

1.查看源码可以知道POST传参有u和returl，returl可以传url，构成ssrf，目标为当前目录check.php

```
<form action="check.php" method="post">
  <input name="u" type="text" class="text" value="Username" onfocus="this.value = ' ';" onblur="if (this.value == ' ') {this.value = 'Username';}" >
  <div class="key">
    <input password="p" type="password" value="Password" onfocus="this.value = ' ';" onblur="if (this.value == ' ') {this.value = 'Password';}">
  </div>
  <input type="hidden" name="returl" value="https://404.chall.ctf.show/">
</form>
```

2.使用gopherus帮助生成针对Gopher协议的payload，SQL语句执行生成/var/www/html/shell.php一句话木马



因为要经过一个服务器才能到底目标点，所以还要将后面的请求在url编码一次

最终payload

3.check.php为目标，u随便传参，returl则传参payload，excute

4.访问shell.php，注入命令在根目录flag.txt得到flag

ctfshow{769ed96e-4694-4c9b-bbad-bb1ee2029749}